

Milton Nation Alumni App — Patient Privacy & HIPAA Architecture Review

Prepared for: Clinical Director, Milton Recovery Centers

From: Ezra Barishansky, Milton Health Group LLC

Date: 2026-06-10

Subject: Clinical sign-off on patient privacy architecture before iOS launch

Estimated read time: 10 minutes

Action requested: Review and sign Section 9 on the last page

1. Executive summary (read this first)

The Milton Nation iOS app is a private alumni community for Milton Recovery Centers and Milton Jefferson alumni. It launches on the Apple App Store. This memo documents how the app handles patient identifying information and protected health information (PHI), confirms compliance with **HIPAA** and **42 CFR Part 2** (the stricter federal regulation governing substance use disorder treatment records), and identifies one remaining gap with a documented remediation plan.

Bottom line: All patient health information and treatment-status indicators flow only through vendors who have signed Business Associate Agreements with us. SMS verification, push notifications, and welcome emails are intentionally brand-anonymous so no third-party SMS, device, or email vendor ever sees information that could identify the recipient as a Milton Recovery patient.

You are not being asked to attest to the legal contracts or the technical security implementation — both are handled by counsel and engineering. You are being asked to confirm that the clinical workflow protections described here (crisis response, content moderation, care-team confidentiality, patient consent and deletion rights) align with the standard of care for the patients this app serves.

2. What patient information the app collects

Category	Specific fields	Sensitivity	Source
Identity	Full name, username, profile photo (optional)	Personal identifier	Patient enters at signup

Category	Specific fields	Sensitivity	Source
Contact	Phone number, email	Personal identifier	Patient enters at signup
Account	Password (hashed), Apple device identifier	Authentication	App-generated
Treatment-related	Facility of origin (Florida or Ohio), treatment program (IOP / PHP / Detox / Residential / OP / Other), sobriety start date	PHI under HIPAA + Part 2	Patient enters at signup
Recovery progress	Days of sobriety, badge milestones earned	PHI	App-calculated
Community content	Posts in alumni feed, comments, likes, photos uploaded with posts	Some may contain PHI (e.g., disclosure of clinical experience)	Patient-generated
Care-team communications	Direct chat messages with assigned counselor / therapist / case manager	PHI / clinical record	Patient + clinician
Crisis indicators	Posts or messages flagged by automated content moderation as crisis-content; admin review notes	PHI of acute clinical significance	App-generated + clinician
Audit records	Login events, admin actions, content moderation decisions, account changes	PHI metadata	App-generated

3. Where each piece of data flows — vendor map

Vendor	What they see	PHI exposure	Business Associate Agreement
Supabase (database, authentication, file storage, server logic)	Everything in Section 2 above	Full PHI processor	✅ HIPAA add-on signed and active at launch (~\$1,000 / month). This includes Supabase's standard BAA covering encryption at rest, encryption in transit, access auditing, breach notification within 60 days, and subcontractor flow-down.
Twilio (SMS verification codes)	Patient's phone number; generic OTP message body ("Your verification code is 123456. It	No PHI processed	Not required. We deliberately removed all brand identifiers from outbound SMS specifically

Vendor	What they see	PHI exposure	Business Associate Agreement
	expires in 5 minutes."). No mention of "Milton Recovery," "Milton Nation," "alumni," or anything that would indicate the recipient is a treatment patient.		to avoid creating a PHI exposure that would require a BAA. Documented in a separate vendor risk memo for legal counsel.
Apple Push Notifications (APNs)	A device-specific opaque token plus the notification text ("New comment on your post" or, for crisis alerts, "URGENT: User may need immediate help" — no patient identifier in either).	No PHI processed	Not required. Apple's standard developer terms govern operational reliability. Notification payloads never contain patient name, phone, treatment facility, or any other identifier.
Apple App Store	App listing metadata only (app name, description, screenshots). No patient data.	No PHI processed	Not required.
Resend (welcome email vendor)	Patient's email address; brand-anonymous welcome email body identifying only the app name "Milton Nation" with no mention of Milton Recovery Centers, alumni status, recovery community, or any treatment-program identifier.	No PHI processed (as of 2026-06-10 — see Section 7 for what changed and why).	Not required under the architecture deployed on 2026-06-10.
GitHub (source code hosting)	App source code only. No patient data.	No PHI processed	Not required.

4. HIPAA and 42 CFR Part 2 controls in place

The app is built to clear both standards. Because Milton Recovery Centers and Milton Jefferson are licensed substance use disorder treatment programs, the records of patients identified as alumni receive the additional protection of 42 CFR Part 2 — meaning patient identity cannot be disclosed to any third party without explicit written consent, and any disclosure must restrict re-disclosure by the recipient.

Confidentiality controls

- All PHI is stored in a Supabase Postgres database, encrypted at rest (AES-256) and in transit (TLS 1.2+).

- Database row-level security policies enforce that patients can only access their own records and the public alumni feed for their facility. Florida patients cannot see Ohio patients' content and vice versa, except for super-admins (Ezra) and care team members assigned to a specific patient.
- Admin and clinician accounts are role-gated. Counselors see only the patients assigned to them; admins see only their facility's patients.
- All authentication uses two-factor: email + password + SMS verification code.

Audit and accountability

- Every admin action — approving a new alumni, reviewing a flagged post, escalating a crisis flag, modifying a profile — is recorded in a tamper-evident audit log with timestamp, actor identity, and action description.
- Every login (success and failure) is logged.
- Every time an admin views a patient's flagged content or chat with a clinician, the access is recorded as an "emergency access event" — supporting the 42 CFR Part 2 minimum-necessary standard.
- Audit logs are retained indefinitely per HIPAA's six-year minimum.

Patient consent

- Patients consent to SMS verification at signup with disclosure displayed in-app immediately above the phone-number entry field.
- Patients consent to push notifications via the iOS system prompt on first app launch — they can decline and the app remains functional.
- Patients can revoke SMS consent at any time by replying STOP to a verification message.
- Patients can revoke all consent and request account deletion at any time from Settings → Delete Account. Deletion is processed within 30 days; during that window the account is restorable. After 30 days the account and all PHI is permanently deleted, except for audit log entries which remain de-identified.

Subcontractor flow-down (42 CFR Part 2 requirement)

The Supabase BAA includes a flow-down clause: any subcontractors Supabase uses to process PHI (their hosting infrastructure, monitoring services, etc.) must accept equivalent HIPAA and Part 2 obligations. Supabase publishes a current subcontractor list.

5. Clinical safety features — what protects patients in distress

This section covers the workflows you would specifically scrutinize as a clinician.

Automated content moderation

- Every post and chat message submitted by an alumni is screened by an on-device content safety engine before submission. The engine recognizes six categories of risk: self-harm, drug

use, alcohol use, eating-disorder behavior, violence, and intimate-partner violence — plus negation patterns (a patient saying "I am NOT going to use" is correctly distinguished from a patient saying "I am going to use").

- Time-immediacy markers ("tonight," "today," "right now") elevate a medium-risk post to crisis-tier automatically.
- The clinical content safety keyword lists were finalized 2026-05-27 (commit `d904e8e`) and are reviewed annually. The lists are written in a configuration file that you, the clinical director, can request access to review and modify without engineering involvement.

Crisis response sheet

- When the engine detects high-risk content, the patient sees a crisis resources screen IMMEDIATELY — before the post is published. The screen shows six tap-to-dial numbers: 988 Suicide and Crisis Lifeline, Crisis Text Line (HOME to 741741), SAMHSA helpline (1-800-662-4357), Milton Recovery Centers FL main line (844-406-4325), Milton Jefferson OH main line (740-715-4673), and 911.
- The patient's post is held — not published to the community feed — and routed to the admin and care-team moderation queue with an URGENT push notification within 30 seconds.
- An assigned counselor or therapist can open a direct chat with the patient immediately from the moderation queue.

Care-team chat

- Patients receive a chat thread with each of their assigned care-team members (case manager, therapist).
- All messages — text, photo, voice — are stored encrypted and routed only to the assigned clinician. Cross-patient communication is not possible.
- A patient cannot initiate chats with other patients. The alumni community is feed-based, not direct-message-based, by design — to preserve the clinical scope of the relationship and avoid creating peer interactions that could compromise treatment.

Sobriety tracking

- Patients log their own sobriety start date at signup. The app calculates days clean automatically and awards milestone badges (30 days, 60 days, 90 days, etc.).
 - Patients can adjust their sobriety date in Settings if they relapse. The relapse-adjustment is recorded in the `sobriety_change_log` with timestamp but is NOT visible to other patients or to the community feed — only to the patient and their care team.
 - A relapse-style edit does NOT automatically trigger a clinical alert. The decision was made to respect patient autonomy and avoid pathologizing self-correction. The care team becomes involved only if the patient subsequently posts crisis content or directly messages their counselor.
-

6. Patient rights protected by the app

- **Right to access:** patients can view, edit, and download all data they have provided (Settings → Export Data).
 - **Right to delete:** patients can delete their account at any time. Permanent deletion within 30 days. PHI is purged; only de-identified audit log entries remain.
 - **Right to restrict:** patients can opt out of push notifications, opt out of SMS messages (reply STOP), and adjust which categories of community content they see.
 - **Right to know who has accessed their record:** patients can request a list of clinician and admin access events for their account.
 - **Right of refusal:** patients can refuse SMS verification at signup, in which case they cannot complete onboarding. This is by design — phone verification is the only way we currently confirm alumni identity. Patients in this situation should be advised by their counselor to contact you directly to complete enrollment via an out-of-band process.
-

7. Resend welcome email — gap identified and closed on 2026-06-10

During the preparation of this memo, we identified that the automated welcome email sent to new alumni applicants via the Resend transactional email service contained language that identified the recipient as a Milton Recovery Centers alumni applicant (specifically: the body referenced "Milton Nation alumni community" and "Milton Recovery Centers" by name, and the footer listed both the Florida and Ohio clinical phone lines). Resend does not hold a HIPAA Business Associate Agreement at the tier we use.

This gap has been remediated. As of 2026-06-10 the welcome email body and subject have been rewritten so that the only Milton-related text Resend sees is the app name "Milton Nation" itself. The treatment-program identifiers "Milton Recovery Centers," "alumni community," "recovery community," and the clinical phone lines have been removed. The recipient learns the specific identity and clinical scope of the Milton Nation community only after they install the app on their phone and authenticate into the Supabase-hosted backend, which is fully HIPAA-covered.

What the welcome email now says:

- Subject: "Welcome to Milton Nation"
- Title: "Welcome to Milton Nation"
- Body: "Your application has been received and is being reviewed."
- Next steps: three generic numbered steps (admin reviews, push notification on approval, sign in).
- Crisis resource: the 988 Suicide and Crisis Lifeline (universal, not patient-identifying).
- Footer: links to Support, Privacy, Terms — no clinical phone numbers, no "Milton Recovery Centers" branding.

Effect: Under the same legal analysis applied to the Twilio SMS architecture, Resend is no longer processing PHI on behalf of Milton Recovery Centers. A BAA is not required, and the welcome email is consistent with the rest of the app's brand-anonymous vendor surfaces.

Engineering record: Welcome email source code at `supabase/functions/send-welcome-email/index.ts`, deployed to production Supabase 2026-06-10. The HIPAA-driven naming convention is documented as an inline code comment so future engineering work cannot accidentally reintroduce the gap.

8. What is not in the app (for completeness)

So you can confirm nothing is missing from the picture:

- The app does not contain any electronic health record (EHR) functionality. It does not store diagnoses, treatment plans, medication lists, lab results, or clinical session notes. The app is for alumni peer support, sobriety tracking, and care-team check-ins — not for clinical documentation. Anything that belongs in the formal medical record stays in Milton Recovery Centers' existing EHR system.
 - The app does not interface with insurance, billing, or claim systems. No financial PHI is processed.
 - The app does not allow video or audio calls — only text-based chat with photo and voice-note attachments.
 - The app does not allow alumni to chat with other alumni directly. All peer-to-peer communication is in the public alumni community feed (moderated).
 - The app does not transmit data to advertisers, analytics third parties, or social media platforms.
-

9. Clinical Director sign-off

I have reviewed the architecture described in Sections 2 through 8 of this memo. I confirm that:

1. The data inventory in Section 2 accurately describes what patient information the Milton Nation app collects, with no clinical information missing or mischaracterized.
2. The vendor flow in Section 3 accurately describes which third parties see which patient information.
3. The HIPAA and 42 CFR Part 2 confidentiality, audit, consent, and subcontractor controls described in Section 4 are sufficient to protect Milton Recovery Centers patients identified as alumni.
4. The clinical safety workflows in Section 5 — automated content moderation, crisis response sheet, urgent care-team push notifications, care-team chat — meet my standard of care for the alumni population this app serves.

5. The patient rights documented in Section 6 are honored by the app and are not in conflict with the rights granted to patients by their original Milton Recovery Centers consent documents.
6. The Resend welcome email remediation described in Section 7 is in production as of 2026-06-10 and closes the identified gap.

I authorize launch of the Milton Nation Alumni App on the Apple App Store.

Name	_____
Title	Clinical Director, Milton Recovery Centers
Date	_____
Signature	_____

Appendix — Where to find more detail if you have questions

Question	Where to look
What exactly is the SMS message that gets sent?	The OTP body is verbatim in Section 3 of this memo.
What does the privacy policy say?	https://miltonrecovery.com/milton-nation-privacy/
What does the terms of use say?	https://miltonrecovery.com/app-terms-of-use/
What does Supabase's HIPAA add-on cover?	Supabase publishes this publicly at supabase.com/hipaa . Their BAA is a standard template with no Milton-specific redlines.
Who can I contact with clinical concerns about the app?	Ezra Barishansky, ebarish@miltonhealthgroup.com
Who can I contact with engineering concerns?	Same as above — Ezra routes engineering questions to the build team.
Can I review the content safety keyword lists?	Yes — request the file <code>Milton Nation Alumni App/Services/ContentSafetyKeywords.swift</code> from Ezra. It is a plain-text configuration file you can read and propose edits to without engineering involvement.